Práctica 5: Credential Access

Objetivo

El alumno reforzará los conceptos discutidos en clase relacionados con el **Tema 3 Identificación de Ataques y Técnicas de Intrusión** haciendo uso de herramientas como John the Ripper para poner en práctica los conceptos discutidos en clase sobre la táctica "TA0006 - Credential Access". Al finalizar la práctica, el alumno aprenderá a:

1. Identificar los métodos implementados en sistemas operativos Linux para la gestión de contraseñas.
2. Utilizar herramientas de código abierto para auditar contraseñas.
3. Ejecutar pruebas de seguridad sobre contraseñas en un entorno controlado.

Entregables

1. Reporte de ejecución. El reporte debe documentar las acciones realizadas durante la ejecución de la práctica, incluyendo una descripción de las acciones ejecutadas y capturas de pantalla que ayuden a explicar y contextualizar las actividades desarrolladas.

Rúbrica

#	Elemento a evaluar	Descripción	Puntaje
1	Estructura y formato del reporte escrito	El reporte deberá incluir todos los elementos para ser evaluado: ● Portada ● Índice de contenido ● Contenido ● Referencias	2
2	Documentación de la sección "Desarrollo"	Elementos a evaluar: ● Se incluye una descripción clara de las acciones realizadas, 1 punto. ● El uso de capturas de pantalla es adecuado, 1 puntos ● Completitud: se documentan todas las actividades correspondientes, 2 puntos.	4

3	Documentación de la sección “Actividades”	Elementos a evaluar: ● Se incluye una descripción clara de las acciones realizadas, 1 punto. ● El uso de capturas de pantalla es adecuado, 1 punto. ● Completitud: se documentan todas las actividades correspondientes, 2 puntos.	4
		TOTAL	**10**

Instrucciones

1. Inicie la máquina virtual “`Evilbox`” configurada en la actividad “Práctica 1: Resource Development”.
2. Inicie la máquina virtual Webserver, disponible en Classroom.
3. Siga los pasos descritos en la sección “Desarrollo” para preparar el entorno necesario, documente las actividades realizadas en el reporte se esta práctica.
4. Realice los ejercicios, actividades o retos propuestos en la sección “Actividades” y documente el procedimiento realizado para resolver cada ejercicio.
5. Una vez que haya finalizado con ambas secciones, complemente su reporte de práctica con los elementos que considere necesarios.
6. Realice su entrega en Google Classroom subiendo su reporte escrito en formato PDF usando la siguiente nomenclatura para el nombre de archivo: NúmeroDeCuenta_PrácticaX.pdf, donde “X” corresponde al número de la práctica actual.

Prerrequisitos

Durante la ejecución de esta práctica se hará uso de las siguientes herramientas:

1. Máquina virtual *evilbox*
2. Máquina virtual *webserver* (webserver.7z, MD5: 7da9a7e0f509aed09d45037e1d8024e0)
3. Herramienta John the Ripper - https://github.com/openwall/john

Desarrollo

A continuación se presentan los pasos necesarios para preparar el entorno virtual que permitirá responder las preguntas del cuestionario correspondiente.

1. Encienda los equipos virtuales *evilbox* y *webserver*.

2. Verifique que exista conectividad entre los equipos *evilbox* y *webserver* mediante el uso de la herramienta nmap. Utilice el siguiente comando para identificar la dirección IP del equipo webserver:

   ```
   sudo nmap -sP 192.168.89.0/24
   ```

   Verifique que el segmento de red corresponde con el mismo segmento en que está trabajando.

3. Utilice las credenciales obtenidas en la “Práctica 3 - Initial Access” para establecer una sesión con terminal interactiva desde el equipo del atacante, *evilbox*, y el equipo víctima, *webserver*. Utilice el siguiente comando con los ajustes correspondientes:

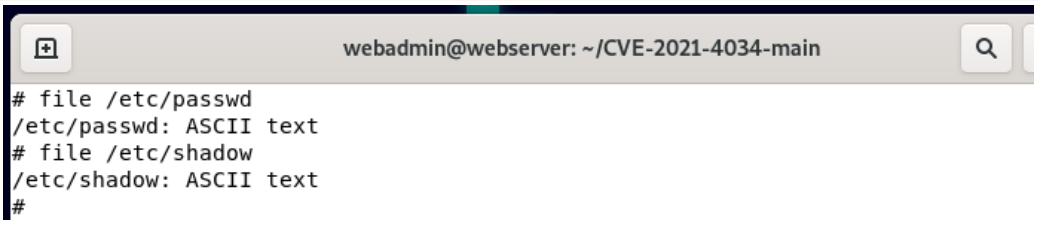
   ```
   ssh -p <PORT> <USER>@<IP>
   ```

4. Explote la vulnerabilidad que permite la escalación de privilegios identificada en la “Práctica 5 - Privilege Escalation”. Utilice el exploit correspondiente e inicie una terminal como el usuario root, como se muestra en la siguiente imagen.

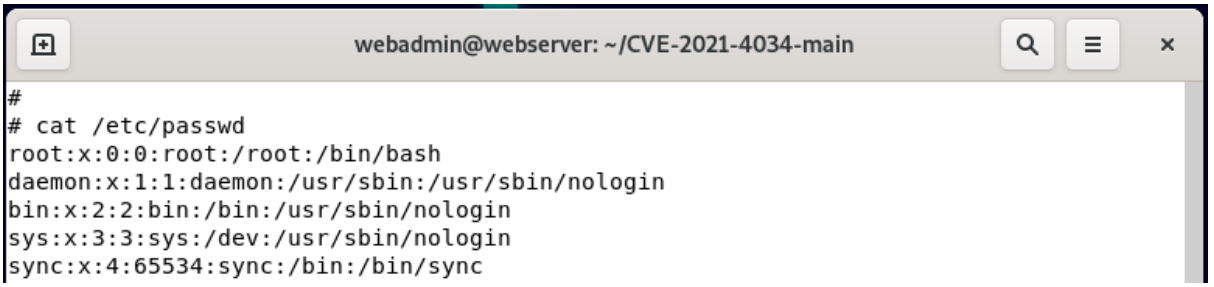
   

5. Una vez que tenga una terminal con privilegios de administración identifique los siguientes archivos en el sistema:

```
/etc/passwd
/etc/shadow
```



Estos archivos contienen el listado de usuarios del sistema así como un hash de sus contraseñas. Utilice el comando `cat` para observar el contenido de cada archivo, como se muestra en las siguientes imágenes.





6. Realice una copia de los archivos *passwd* y *shadow* para transferirlos al equipo *evilbox*. Recuerde que existen diferentes formas de realizar este procedimiento, documente los pasos realizados en el reporte correspondiente.

7. En el equipo *evilbox*, verifique que el contenido de ambos archivos se copió completamente. Utilice un algoritmo de digestión para validar la integridad de los archivos, como se muestra en la siguiente imagen.



8. En el equipo *evilbox*, instale la herramienta John the Ripper. Utilice el siguiente comando:

```
sudo apt-get install john
```

La herramienta John the Ripper está diseñada para realizar auditoría de seguridad a contraseñas mediante un procedimiento conocido como *off-line cracking*, es decir, los intentos de romper la seguridad del mecanismo de protección de la contraseña se realizan en el equipo, y con los recursos, del atacante y no en el equipo víctima.

La herramienta funciona con un archivo que fusiona los contenidos del archivo *passwd* y *shadow* y con un diccionario de contraseñas conocidas.

9. Utilice la herramienta John the Ripper para fusionar los contenidos de passwd y shadow utilizando el siguiente comando con los ajustes correspondientes:

```
sudo unshadow passwd.txt shadow.txt > unshadow.txt
```

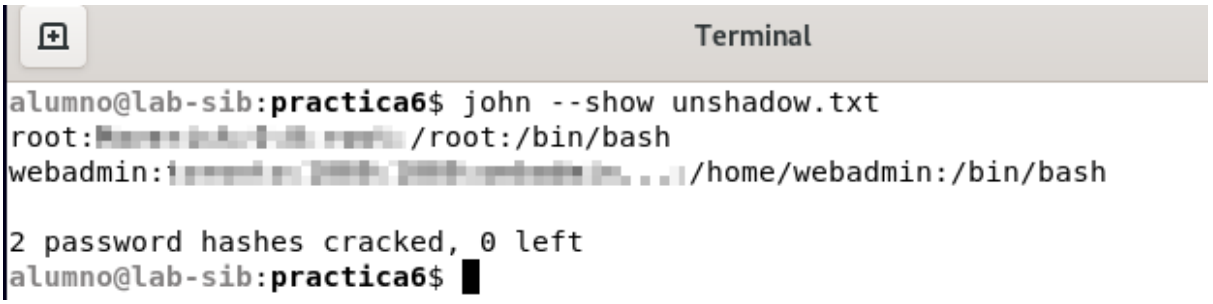
10. A continuación, utilice un diccionario de contraseñas conocidas y comience con el proceso de *off-line cracking.* Utilice el siguiente comando:

```
john --wordlist=10-million-password-list-top-1000000.txt
unshadow.txt
```

```
alumno@lab-sib:practica6$ john --wordlist=10-million-password-list-top-1000000.txt u
nshadow.txt
Warning: detected hash type "sha512crypt", but the string is also recognized as "sha
512crypt-opencl"
Use the "--format=sha512crypt-opencl" option to force loading these as that type ins
tead
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (sha512crypt, crypt(3) $6$ [SHA512 2
56/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
[redacted]          (webadmin)
[redacted]          (root)
2g 0:00:00:05 DONE (2024-05-04 13:37) 0.3497g/s 1275p/s 1544c/s 1544C/s roswell..twi
ggy
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

11. Finalmente, utilice el siguiente comando para revisar los resultados cuando el proceso haya terminado. Si se utilizó un diccionario que contiene la contraseña correcta obtendrá una salida similar a la siguiente imagen:

```
john --show unshadow.txt
```



Actividades

Utilice el entorno preparado en los pasos anteriores para responder las siguientes preguntas, documente el procedimiento realizado para responder cada una e incluyas en el reporte.

1. ¿Cuál es el hash SHA256 del archivo *passwd* original en el equipo *webserver*?

2. ¿Cuál es el hash SHA256 del archivo *shadow* original en el equipo *webserver*?

3. ¿Cuál es el hash de la contraseña del usuario *root*?

4. ¿Cuál es el hash de la contraseña del usuario *webadmin*?

5. ¿Cuál es la contraseña en claro del usuario *root*?

6. ¿Cuál es la contraseña en claro del usuario *webadmin*?

Referencias

Openwall. (s.f.). *John the Ripper* [Software de auditoría de contraseñas]. GitHub. https://github.com/openwall/john